

Rapport de Gestion d'Incident ISO 27001

Vulnérabilité SQL Injection dans DVWA

Introduction

Ce rapport vise à documenter la détection, l'analyse et l'exploitation d'une vulnérabilité de type SQL Injection dans un environnement contrôlé tel que Damn Vulnerable Web Application (DVWA). Cette activité cherche à comprendre et démontrer comment une mauvaise validation des entrées peut compromettre un système web. Le processus a inclus l'installation de l'environnement jusqu'à l'exécution de l'attaque, ainsi que la résolution de problèmes techniques liés à la configuration de la base de données.

Description de l'incident

Lors des tests de sécurité réalisés sur l'application DVWA, une vulnérabilité majeure a été identifiée dans le module SQL Injection. Cette faiblesse permet à un attaquant d'injecter des commandes SQL via le champ de saisie de l'identifiant utilisateur, ce qui pourrait compromettre à la fois la confidentialité et l'intégrité des données stockées dans la base de données.

Avant que la vulnérabilité ne puisse être exploitée, un problème a été détecté au niveau des permissions de l'utilisateur root dans MySQL. Cette erreur empêchait la connexion entre DVWA et la base de données, et affichait le message :

Access denied for user 'root'@'localhost'

La solution à ce problème a été de configurer le fichier *config.inc.php* avec les identifiants corrects et de lui attribuer les bonnes permissions dans MySQL.

Description du processus

- **Phase 1:** Procéder à l'installation de DVWA dans un environnement Linux, dans ce cas une machine virtuelle Kali
- **Phase 2:** Vérifier qu'Apache et MySQL sont actifs et les configurer
- **Phase 3:** Résolution des erreurs possibles, dans ce cas, les permissions de l'utilisateur root
- **Phase 4:** Attribution des permissions utilisateur avec:

```
sudo chown -R www-data:www-data /var/www/html/DVWA/  
sudo chmod -R 755 /var/www/html/DVWA/
```

Parallèlement, attribuer les permissions à root avec:

```
GRANT ALL PRIVILEGES ON DVWA.* TO 'root'@'localhost' IDENTIFIED  
BY 'kali';  
FLUSH PRIVILEGES;
```

- **Phase 5:** Accès à <http://localhost/DVWA/setup.php>, où une page s'affiche et la base de données est créée via l'interface.
- **Phase 6:** Accès au module "SQL Injection" disponible sur la plateforme
- **Phase 7:** Injection de la chaîne suivante dans le champ ID utilisateur :

1' OR '1'=1

- **Phase 8:** Obtention de multiples résultats d'utilisateurs stockés dans la base de données, démontrant que l'application est vulnérable à SQL Injection.

Impact de l'incident

L'exploitation de cette vulnérabilité a permis:

- D'accéder à des informations sensibles de tous les utilisateurs stockés dans la base de données
- D'exécuter des requêtes non autorisées pouvant aller jusqu'à la modification ou suppression de données critiques
- De révéler les noms d'utilisateur et la structure interne de la base de données

Si ce scénario s'était produit dans un environnement réel, l'exploitation de cette vulnérabilité pourrait constituer une violation légale du RGPD si des données personnelles étaient compromises, enfreignant les articles 5, 25, 32 et 33 du RGPD / LOPDGDD.

Cela constitue une atteinte au traitement, à la sécurité et à la protection des données ainsi qu'à la gestion de la sécurité de l'information.

Recommandations

1. **Validation des entrées:** Utiliser des requêtes préparées ou des requêtes paramétrées pour éviter les injections.

2. **Gestion des erreurs** : Configurer l'application pour qu'elle n'affiche pas les erreurs détaillées de la base de données à l'utilisateur.
 3. **Tests de sécurité** : Effectuer régulièrement des analyses de vulnérabilités et des tests d'intrusion
 4. **Principe de moindre privilège**: Éviter d'utiliser l'utilisateur root dans les applications web. À la place, créer un utilisateur limité ayant uniquement les droits nécessaires pour lire et/ou écrire dans la base de données concernée
 5. **Formation** : Former les développeurs aux bonnes pratiques de codage sécurisé et de gestion des incidents
-

Bilan

L'exercice avec DVWA a démontré qu'il est possible d'exploiter une vulnérabilité de type SQL Injection pour accéder à des informations sensibles sans autorisation. Il a également mis en lumière comment le manque de rigueur, notamment en accordant des accès excessifs à certains utilisateurs au niveau de la base de données, peut représenter un risque sérieux pour la sécurité.

Cet incident montre qu'il est nécessaire de mettre en place des mesures de protection adaptées dès les premières étapes du développement logiciel, ainsi qu'un suivi régulier pour garantir l'intégrité du système.

Dans un environnement réel, cet exploit pourrait être considéré comme une violation des lois sur la protection des données telles que la **LOPDGDD** (Loi Organique sur la Protection des Données et la Garantie des Droits Numériques) et le **RGPD** (Règlement Général sur la Protection des Données). Cela porterait atteinte aux principes fondamentaux de confidentialité et d'intégrité des données, en plus de contrevenir aux obligations légales liées à la sécurité des données traitées.

C'est pourquoi il est essentiel de comprendre que les défaillances techniques ne représentent pas seulement un risque opérationnel, mais également un risque juridique et réputationnel pour toute entité.